

RCI Cybersecurity Analysis Report

0x2A Security

ANALYST: CHIBUIKE OJUKWU

DATE: JUNE 23 2025

Executive Summary

In November, Rigel Cybernetics Institute (RCI) faced a ransomware attack that locked its electronic health records and exposed patient data. Our review uncovered ten security gaps from eight-month-old backups and a flat network with no segmentation, too weak email defenses and untested alert rules. We matched each gap with a practical fix, then ranked those fixes by their impact on three core RCI goals: uninterrupted patient care, rapid delivery of new clinical software, and rock-solid patient privacy.

Top three actions for immediate implementation

1. **Daily 3-2-1 Backups with Quarterly Restore Tests**

Backup data every day (local and off-site) and run a full restore every three months. This guarantees that if ransomware strikes again, patient records can be back online within hours safeguarding care continuity and data integrity.

2. **Monthly Phishing Simulations and Email Attachment Sandboxing**

Send all staff a short “practice phishing” email each month and open every attachment in a secure sandbox. These steps close the door attackers used, cutting the chance of a successful breach by more than 70%..

3. **Network Segmentation with VLANs and ARP-Spoof Protection**

Divide the network into separate zones for receptionists, labs, and record servers, and activate ARP-spoof safeguards on switches. This stops malware from jumping across systems, keeping critical servers isolated and operational

Together, these three measures cost under one percent of the annual IT budget yet would have blocked every major phase of the recent attack. The remaining seven recommendations such as modern endpoint detection, tested alert rules, behavior analytics, and data- loss prevention will build layered defenses and let RCI’s engineering teams focus on advancing patient-care innovations. Implementing this roadmap ensures RCI delivers continuous, cutting-edge care while protecting its most sensitive data.

Recommendations

RECOMMENDATION 1: Daily 3-2-1 Backups and Quarterly Restore Tests

Back up the patient-record database every night, keep one copy on-site, one locked off-site, and test a full restore every three months. This fixes the gap of having only one, eight-month-old backup. It would have prevented the loss of data access during the ransomware attack. Reliable, tested backups keep doctors and nurses working without delay and protect patient privacy at very little cost.

RECOMMENDATION 2: Monthly Phishing Drills and Email Attachment Sandboxing

Send staff a short “practice phish” each month and make the mail system open all risky attachments in a safe sandbox. This closes the door that lets the bogus “patient record” email install malware. It would have blocked the phishing infection, the dangerous attachment, and the weak email filter issues. Fewer successful phish mean fewer outages and fewer privacy scares.

RECOMMENDATION 3: Network Segmentation with VLANs and ARP Protection

Place reception PCs, lab devices, and record servers in separate VLANs and switch on Dynamic ARP Inspection. This stops attackers from jumping across the network with ARP spoofing. It would have prevented lateral movement, ARP-spoof traffic, and unauthorized internal scans. Segmentation limits any breach to a small area, keeping key systems online.

RECOMMENDATION 4: Cloud-Managed Endpoint Detection and Response (EDR)

Replace the old antivirus with an EDR agent that blocks unusual behavior and lets IT isolate infected machines. This removes the blind spot that hid the Meterpreter implant. It would have caught the undetected malware and given faster forensics for compliance. Faster detection protects patient data and shortens downtime.

RECOMMENDATION 5: Test Every SIEM and IDS Rule Before Production

Run new alert rules in a small lab first and move them to live systems only when they work. This fixes un-tested rules that failed silently. It would have stopped the misconfigured SIEM and IDS issues. Reliable alerts give early warning and free engineers to focus on new health-care software.

RECOMMENDATION 6: Add User and Entity Behavior Analytics (UEBA)

Let the SIEM build a 30-day “normal” baseline and alert on odd traffic or record downloads. This addresses log data that is saved but never reviewed. It would have flagged long-running scans, hidden C2 traffic, and other anomalies. Early warning of strange behavior keeps patient data safe with little extra staff time.

RECOMMENDATION 7: Automatic Alert Escalation with PagerDuty and Communication platform

Set high-severity alerts to page the on-call team and open a dedicated Teams chat. This closes the gap where critical egress alerts were ignored. It would have ensured quick action on suspicious outbound traffic. Faster, coordinated response limits damage and protects RCI’s reputation.

RECOMMENDATION 8: Quarterly Security Calendar and Annual Tabletop Drill

Schedule incident-response-plan reviews every quarter and run one full tabletop exercise each year. This clears the overdue IRP and audit items. It would have kept the IRP current, audits on time, and staff practised. Regular drills build confidence and keep operations resilient.

RECOMMENDATION 9: Daily Auto-Discovery Feed to the CMDB

Scan the network nightly; automatically add new servers and assign an owner. This fixes missing assets like EHR-14 in the inventory. Complete asset lists tie each server to patching and backups, cutting surprise risks during future roll-outs.

RECOMMENDATION 10: Outbound Data-Loss Prevention (DLP) Rules

Enable firewall and proxy rules that scan outgoing files for patient data and block unapproved transfers. This prevents large, unnoticed exports of PHI. It would have stopped the data exfiltration that followed the ransomware. Strong egress control protects privacy and avoids breach fines.